Chapter 5

Understanding Techniques for Hiding and Scrambling Information

IT 360

Hiding vs. Scrambling

Technically savvy criminals hide or protect evidence so investigators are less likely to find it.

- **Steganography** – Greek *steganos*, "covered/protected"
  - The message is **hidden**
- **Cryptography** – Greek *kryptos*, "hidden"
  - The message is **scrambled**, not hidden per se
- Both techniques trace back to ancient Greece

Topics

- Understanding the use and detection of steganography
- Encryption

Goals

- Understand, use, and detect steganography
- Understand and utilize basic cryptography
- Understand general cryptanalysis techniques

Steganography

What Is Steganography?

The art and science of writing **hidden messages**

- Goal: even if intercepted, it is not clear anything is hidden
- Most common today: hiding messages **in pictures**
- Most common method: **least significant bit (LSB)**

Least Significant Bit (LSB)

Change the **last** bit of a byte → smallest possible change

Binary	Decimal	Change
`11111111`	255	original
`01111111`	127	first bit flipped – major change
`11111110`	254	last bit flipped – trivial change

- If the LSB already matches the payload bit → **no change at all**

LSB in Images

- 24-bit color: Red, Green, Blue each 0–255
- Changing Green from **101** → **100** (one bit) is invisible to the eye
- Images have thousands to millions of pixels → lots of room to hide data
- Magnifying in Photoshop or GIMP will not reveal it
- Only a **bit-by-bit comparison** with the original suggests hidden data

Key Terms

- **Payload** – the information to be covertly communicated
- **Carrier** (carrier file) – the signal, stream, or file the payload hides in
- **Channel** – the type of medium used
  - **Passive** – photos, video, sound files
  - **Active** – VoIP call, streaming video

Steganography Tools

No longer requires programming skill – free tools do it for you:

Tool	Use
QuickStego	Very easy, very limited
Invisible Secrets	More robust; free and commercial versions
MP3Stego	Hides payload in MP3 files
Stealth Files 4	Sound, video, and image files
StegVideo	Hides data in a video sequence
Deep Sound	Hides data in sound files

Historical Steganography

- **Ancient China** – notes wrapped in wax and swallowed
- **Ancient Greece** – message written on a messenger's shaved head; hair regrown
- **Johannes Trithemius** (1462–1516) – each letter taken as a word from a specific column
- **WWII French Resistance** – messages in invisible ink on couriers' backs

Dead Drops

- Criminals, terrorists, and others cache steganized files on **unsuspecting third parties'** servers or file stores
- Recipient retrieves the data – no physical meeting
- Third party never knows

Beyond Images

- **Steganophony –** hiding messages in sound files
  - LSB method or **echo method** (extra sound in an echo carries data)
  - Static (MP3) or dynamic (VoIP)
- **Video steganography –** large files → lots of room to hide data
- **BPCS** (Bit-Plane Complexity Segmentation Steganography)
  - Complex areas of the bit planes replaced with the payload
  - 24-bit file = 24 bit planes

Steganalysis

Steganalysis

Analyzing a file for hidden content – at best shows a **likelihood**

- **Close-color pairs** – two colors differing only in the LSB
  - Seen too frequently → hidden message may be present

Easy Indicators

- **Metadata dates**
  - Created date = when created *on that device* (e.g., downloaded)
  - Last-modified **newer** than created on a music file → modified after download
  - Suspect doesn't edit music? → consider steganography
- **File size**
  - Stego tools often bloat the carrier
  - 100 vacation photos at ~2 MB, one at 4 MB → analyze that one

Technical Methods

- **Raw quick pair –** statistics on unique colors vs. close-color pairs in a 24-bit image
- **Chi-square –** compares theoretical vs. calculated population of LSB values
- **Audio –** examine noise distortion in the carrier
- **Forensic suites –** FTK (dedicated image detection engine) and EnCase
- **Free tools –** McAfee detection tool, Steg Secret, StegSpy

Detection Limits

- Depends on **payload size vs. carrier size**
  - 10 KB text in a 2 MB image → hard to detect
  - 1 MB image in a 4 MB image → easier
- Some stego tools are more efficient than others
- Hidden well **and encrypted** → may be impossible to detect

Hands-On: Invisible Secrets

1. **Select Action** – encrypt/hide or extract/decrypt
2. **Select Carrier File** – the image to hide in
3. **Select file(s) to hide** – text or another image; optionally encrypt

That's it – which is why criminals use it.

Common in organized crime, spying, and terrorism cases.

Case: Osama Bin Laden

- Hard drives seized in the raid on his compound
- Contained pornographic videos
- Forensics showed the videos held **steganographically hidden messages**
- Used to communicate with terrorist cells

MP3Stego & Deep Sound

MP3Stego – hide text in MP3 files

```
encode -E data.txt -P pass sound.wav sound.mp3
decode -X -P pass sound.mp3
```

- `-E` file to hide, `-P` password (payload is encrypted)
- `-X` extract and decrypt

Deep Sound – free GUI; hides files in mp3, wav, cda, and more

Free + easy → hidden evidence more likely than in the past

Encryption

Cryptography

Not hiding the message – **obfuscating** it so it cannot be read

- Stego: examiner may not know a message exists
- Crypto: message is obvious, but can't be deciphered
- *kryptós* (hidden) + *gráfo* (I write)

Terms

- **Cryptography** – study of encryption/decryption methods
- **Cryptanalysis** – study of breaking ciphers
- **Cryptology** – both combined

Historical Ciphers

Not secure today – cracked in seconds by computers.

Useful for learning the core concepts.

Caesar Cipher

Substitution cipher: **shift** each letter by a fixed number

Plaintext	Shift	Ciphertext
A CAT	+2	C ECV
A CAT	+3	D FDW

- Past Z → wrap back to A
- Julius Caesar reputedly used +3

Breaking the Caesar Cipher

1. **Brute force** – try every key
    - **Key space** = 26 possible keys
2. **Letter/word frequency**
    - Most common 1-letter word: *a*; 3-letter word: *the*
    - Common doubles: *ee*, *oo*
    - Doable with pen and paper in under 10 minutes

Core Crypto Vocabulary

- **Plaintext** – the text you want to encrypt
- **Ciphertext** – the result after algorithm + key
- **Key** – the number that unlocks it
  - Caesar: a single digit like +2
  - AES: a 128-bit number
- **Monoalphabet** (single-alphabet) substitution – all letters shifted the same

Atbash, ROT13, Scytale

- **Atbash –** Hebrew scribes; reverse the alphabet
  - A → Z, B → Y, C → X
- **ROT13 –** Caesar with a fixed shift of 13
  - A CAT → N PNG
- **Scytale –** Spartan rod/baton (7th century BC)
  - Write across a leather strip wrapped on a rod
  - Both parties need the same-diameter rod – the "key"

Playfair Cipher

- Charles Wheatstone, 1854; popularized by Lord Playfair
- Used by British military in WWI (and some in WWII)
- Encrypts **digraphs** (pairs of letters)
- 5 × 5 table: keyword first, then remaining letters; **I/J combined**

F	**A**	**L**	**C**	**O**
N	B	D	E	G
H	I/J	K	M	P
Q	R	S	T	U
V	W	X	Y	Z

Keyword: **falcon**

Using Playfair

- Split plaintext into digraphs: "attack at dawn" → `At ta ck at da wn`
  - Duplicate letter in a pair → second becomes X ("dollar" → "dolxar")
  - Odd letter at the end → pad with Z
  - Remove punctuation; spell out numbers
- Pair letters form a **rectangle** in the table
  - **AT**: A upper-left, T lower-right → take the other two corners → **CR**

Multialphabet Substitution

Multiple shifts used in rotation

- Shifts (+2, −2, +3): **A CAT → C ADV**
  - First A → C, second A → D
- Harder than Caesar, still pen-and-paper breakable
- Computers crack it quickly – considered very weak

Vigenère Cipher

- Giovan Battista Bellaso, 1553 (misattributed to Blaise de Vigenère)
- Series of monoalphabet ciphers selected by a **keyword**
- Keyword letter on top + plaintext letter on left → ciphertext

Plaintext	**c**	**a**	**t**
Keyword	h	o	r
Ciphertext	**j**	**o**	**k**

Keyword *horse*: **cat** → **jok**

The Enigma Machine

- WWII Germany – electromechanical **rotor-based** cipher
- Multialphabet substitution done by machinery
- Same key gives different output each press (A → F, then A → D)
- 26 possible alphabets
- Allied equivalents: British **TypeX**, American **SIGABA** (more secure)

Modern Cryptography

Two Groups

- **Symmetric** – same key encrypts and decrypts
- **Asymmetric** – different keys encrypt and decrypt

Beware "Too Good to Be True"

- Amateurs often invent "unbreakable" algorithms – usually broken quickly
- Some vendors sell insecure crypto out of greed or ignorance

Kerckhoffs' Principle

- Security depends **only on secrecy of the key**, not the algorithm
- Published algorithms get analyzed and strengthened
- Opposite = "security by obscurity" – does not add secrecy

Symmetric Cryptography

- Same key encrypts and decrypts
- Two keys (one each direction) is still symmetric
- Historically the only type until recently

Substitution – swap part of plaintext for matching ciphertext (Caesar, Atbash, Vigenère)

Transposition – swap blocks around

- "I like ice cream" → `ikel I creiceam`

Modern ciphers combine both, at the bit level

Block vs. Stream Ciphers

- **Block cipher –** encrypts fixed-size blocks (64-bit common; AES uses 128-bit)
- **Stream cipher –** encrypts one bit at a time

If the algorithm is **mathematically sound**:

- Larger block size → more security
- Larger key size → more resistance to brute force
- Secure round function → more rounds = more security (to a point)

Not sound? Bigger keys won't help – back to Kerckhoffs.

Binary Operations Review

```
AND          OR           XOR
 1101         1101         1101
 1001         1001         1001
 ----         ----         ----
 1001         1101         0100
```

XOR is reversible

```
 0100   (result)
 1001   (second number)
 ----
 1101   (first number back)
```

The Feistel Function

Horst Feistel – basis of most block ciphers

1. Split block into halves $\mathbf{L_0}$ and $\mathbf{R_0}$
2. Apply **round function F** to one half
3. **XOR** F's output with the other half
4. **Swap** the halves
5. Repeat for N rounds

Feistel ciphers differ only in **F** and the **number of rounds**

DES – Data Encryption Standard

- IBM, early 1970s; from Feistel's **Lucifer**, altered with NSA
- U.S. standard until the 1990s; a Feistel cipher

1. 64-bit blocks
2. 16 rounds using a **56-bit key**
3. Scrambled with a swapping algorithm
4. Final transposition

- Round keys: 56-bit key split into 28-bit halves, shifted 1–2 bits per round, 48 bits selected
- **8 S-boxes** – lookup tables, 6 bits in → 4 bits out

DES Round Function F

1. Expand 32-bit half → 48 bits
2. XOR with 48-bit round key
3. Split into eight 6-bit sections
4. Each through its own S-box → 4 bits (32 total)
5. Transpose output bits

Weakness: algorithm is sound, **key is too short**

- Key space = 2^{56} → modern brute force breaks it

Triple DES (3DES)

Interim fix while a replacement was chosen

Encrypt K_1 → Decrypt K_2 → Encrypt K_3

Option	Keys	Security
1	All three different	Most secure
2	$K_1 = K_3$	Middle
3	All three the same	Least secure

- **2DES –** barely more secure, more costly; rarely used
- **4DES –** never implemented; too scrambled (plaintext blocks leaked)

AES – Advanced Encryption Standard

- **Rijndael** – Joan Daemen & Vincent Rijmen (Belgium)
- Replaced DES in 2001 after 5-year contest (15 candidates); **FIPS 197**
- Key sizes: **128, 192, 256** bits; block size: **128** bits
- **Not** Feistel – substitution-permutation matrix
- Operates on a 4 × 4 byte matrix called the **state**
- NSA approves AES-256 for Top Secret data

AES Steps

1. **Key expansion** – round keys from Rijndael's key schedule
2. **Initial round** – AddRoundKey
3. **Rounds**
    - **SubBytes** – each byte replaced via Rijndael S-box
    - **ShiftRows** – row 1 unchanged, row 2 shift 1, row 3 shift 2…
    - **MixColumns** – combine the 4 bytes in each column
    - **AddRoundKey** – XOR subkey with the state
4. **Final round** – SubBytes, ShiftRows, AddRoundKey (no MixColumns)

Other Symmetric Algorithms

- Blowfish
- Serpent
- Skipjack

AES = most used today; **DES** = classic Feistel example

Cryptographic Hashes

1. **One-way –** cannot "unhash"
2. **Fixed-length** output for any input
3. **Collision resistant –** two inputs → same output should be extremely unlikely

Password storage (Windows)

- "password" → `0BD18106389C9239016320B50D3E896693A96DF`
- Hash stored in the **SAM** file
- Logon: hash what you type, compare to SAM

Common: **MD5**, **SHA** (SHA-1 → SHA-256)

Asymmetric Cryptography

Two keys: one **encrypts**, another **decrypts**

RSA

- Rivest, Shamir, Adleman – MIT, 1977
- Most widely used public key algorithm
- Security: **factoring** a large integer into primes is hard

RSA Key Generation

1. Pick two large primes **p** and **q**
2. **n = p × q**
3. **m = (p − 1)(q − 1)** – Euler's Totient
4. Pick **e** coprime to m
5. Find **d** where (d × e) mod m = 1

- **Public key:** e, n
- **Private key:** d, n

Modulo = remainder after division (8 mod 3 = 2)

RSA Encrypt / Decrypt

Encrypt: $C = M^e \bmod n$

Decrypt: $P = C^d \bmod n$

Toy example

- $p = 5, q = 11 \rightarrow n = 55, m = 40$
- $e = 3, d = 27$ ($3 \times 27 = 81, 81 \bmod 40 = 1$)
- $M = 2 \rightarrow C = 2^3 \bmod 55 =$ **8**
- $C = 8 \rightarrow 8^{27} \bmod 55 =$ **2**

Real keys: 1,024 / 2,048 / 4,096 bits

Diffie-Hellman & Others

Diffie-Hellman

- Two parties establish a **shared key over an insecure channel**
- Used to exchange a symmetric key
- Diffie & Hellman, 1976 (Malcolm J. Williamson at British intelligence first – classified)
- Enabled e-commerce, e-banking

Other asymmetric algorithms: MQV, Elliptic Curve, DSA – all based on number theory

Breaking Encryption

Cryptanalysis

- Techniques other than brute force to uncover a key
- Also: academic or knowledge-based code breaking
- Used to test algorithms (e.g., hash collisions)
- No guarantee of success – long and tedious

Classic Techniques

Frequency analysis

- Letter frequencies reveal key info
- Effective vs. Caesar, Vigenère; not modern crypto
- *the*, *and* common 3-letter words; *a*, *I* single letters; *ee*, *oo* doubles

Kasiski examination (Friedrich Kasiski, 1863)

- Attacks polyalphabetic ciphers like Vigenère
- Repeated strings → deduce keyword length *n*
- Split ciphertext into *n* columns → each is a monoalphabet → frequency analysis

Modern Attack Methods

Attack	Attacker Has
Known plaintext	Plaintext/ciphertext samples (e.g., email signature blocks)
Chosen plaintext	Ciphertexts for plaintexts they choose
Ciphertext-only	Only ciphertexts – most likely, hardest
Related-key	Chosen plaintext under two different keys

Advanced: differential and integral cryptanalysis

Tools & Social Engineering

- Strong, correctly implemented encryption may be uncrackable
- Passwords are cracked more often than encrypted data
- **Social engineering** – get keys before encryption
  - Dumpster diving
  - Lying to obtain keys or passwords
  - Taking a job at the target

Rainbow Tables

- Martin Hellman, 1980 – **time-memory tradeoff**
- Precalculated hashes for every password in a character space (a–z, a–zA–Z0–9…)
- Look up the hash → find the original text
- **OSForensics** can build small, suspect-specific tables → faster

Ophcrack & John the Ripper

Ophcrack – uses rainbow tables; strong on Windows local passwords

1. Download, burn image to CD
2. Boot target from CD
3. Linux grabs the password file, cracks it, outputs usernames + passwords

John the Ripper

- Free, command-line only; custom word lists
- Long-standing, respected by security and hacking communities
- **passwdqc** checks passwords resist John

Quantum Computing & Cryptography

- **Qubit –** data stored in quantum states (photon polarization, electron energy)
- **Decoherence –** state held only briefly; no fully working quantum computer yet
- Once solved, quantum computers can efficiently:
  - **Factor large integers** → breaks RSA
  - **Solve discrete logarithms** → breaks Diffie-Hellman, ElGamal, MQV
- **NIST** post-quantum cryptography standardization in progress

Summary

- **Steganography** hides data; easy to do, used even by terrorist groups
- LSB changes are invisible; detect via close-color pairs, metadata, file size, chi-square
- **Cryptography** scrambles data with a key; stego and crypto can combine
- Historical ciphers: Caesar, Atbash, ROT13, Scytale, Playfair, Vigenère, Enigma
- Symmetric: Feistel, DES, 3DES, AES; hashes: MD5, SHA
- Asymmetric: RSA, Diffie-Hellman
- Cryptanalysis: frequency analysis, Kasiski, known/chosen plaintext, rainbow tables